

THREAT REPORT: AI-DRIVEN CAMPAIGN TARGETS PAPER CUT NG/MF GLOBALLY

Visual Summary



Summary

The observed cluster of activity leverages the CVE-2026-81578 vulnerability to compromise PaperCut NG/MF installations. Exploitation is combined with credential-theft techniques and extensive lateral movement across a wide range of sectors. Victims span dozens of countries, including the United States, Australia, Germany, Brazil, and many others. Priority should be given to enforcing MFA on all accounts, disabling dormant or over-privileged accounts, monitoring for impossible-travel and anomalous logons, and patching CVE-2026-81578 on all affected systems.

Threat Overview

The threat actor behind this campaign remains unidentified. No specific malware families were reported. The operation exploits CVE-2026-81578 (also referencing CVE-2026-82078) to gain initial access to

PaperCut NG/MF services. Targets encompass organizations in education, retail, hospitality, technology, NGOs, manufacturing, energy, government, healthcare, and finance across a broad list of nations.

Attack Chain and Priority Control

The campaign follows a multi-stage chain:

1. **Active scanning (T1595)** to locate vulnerable PaperCut endpoints.
2. **Exploitation of public-facing applications (T1190)** using CVE-2026-81578.
3. **Credential dumping from LSASS (T1003.001) and NTDS (T1003.003)** followed by **Pass-the-Hash (T1550.002)** and **Kerberoasting (T1558.003)**.
4. **Domain account abuse (T1078.002)** to move laterally via **SMB/Windows admin shares (T1021.002)** and **protocol tunneling (T1572)**.
5. **Execution of PowerShell (T1059.001) and Windows command shell (T1059.003)** scripts, often obfuscated (T1027).
6. **Ingress tool transfer (T1105)** and deployment of additional payloads.
7. **Data exfiltration to cloud storage (T1567.002)** and, where desired, **data destruction (T1485)** with subsequent **file deletion (T1070.004)**.

Priority technique: T1078.002 Domain Accounts

Priority control (as stated in the source): Enforce MFA on all accounts; disable dormant and over-privileged accounts; alert on impossible-travel and anomalous logons. In parallel, patch CVE-2026-81578 on all affected systems.

Infrastructure and Corroboration

Third-party enrichment indicates that the command-and-control infrastructure is hosted by Hosting Industry Limited. AbuseIPDB reports no indicators with confidence above 80 %, and no malware families were corroborated by abuse.ch.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1003.002 Security Account Manager
- T1190 Exploit Public-Facing Application
- T1021.002 SMB/Windows Admin Shares
- T1572 Protocol Tunneling
- T1003.001 LSASS Memory
- T1595 Active Scanning
- T1090 Proxy
- T1136.002 Domain Account
- T1059.001 PowerShell

- T1027 Obfuscated Files or Information
- T1203 Exploitation for Client Execution
- T1567.002 Exfiltration to Cloud Storage
- T1078.002 Domain Accounts
- T1059.003 Windows Command Shell
- T1485 Data Destruction
- T1070.004 File Deletion
- T1550.002 Pass the Hash
- T1105 Ingress Tool Transfer
- T1003.003 NTDS
- T1558.003 Kerberoasting

Analytical Scores

- Priority technique (graph chokepoint): T1078.002 Domain Accounts (centrality 0.2974).
- Operational risk: Critical (score 1.0, reaches impact).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4734; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Cinnamon Tempest	0.4734
Wizard Spider	0.4453
Play	0.4394
Ember Bear	0.428
Aquatic Panda	0.4244

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
IP	45[.]158[.]196[.]75	AbuseIPDB 0% (US) · AS207461 Hosting Industry Limited
Domain	pc-sec[.]hiv	
Domain	pc-security[.]hiv	
Domain	pc-sys-reg[.]hiv	
Domain	pc-sys[.]hiv	
Domain	pc-system[.]hiv	
URL	hxxp://45[.]142[.]193[.]132:8000/lisa_collect[.]exe	
Hash	c3f7109963b9599eb93fd9a97a4ffa38e672642b35b33608d69e6bbf9f19da4e	
Hash	14779d0d7ad6be3d7bf9ed78e4ab6016f22dfa7bc8b5d9c43b56011f7fe2ea19	
Hash	528cd4e69ecfa5191adbcf6ef28667bf	
Hash	974dec9ff4c8f9ccb0937c96d513347	
Hash	a6437ac3d6798090a218520985d36a3f	
Hash	ce870a91e8d27e8f663f0687abc60b04	
Hash	fc92dfafa7aa741c5f2b9cbcf75d1d19	
Hash	159989f088c3d4bc54e1acb93b12924a14db8c0b	
Hash	4e24bfae6ea02175d367e8ba3fbbc38990e95bc0	
Hash	577fa0267c491d8aa4531e91b0ba402db24932f4	
Hash	77e981d0b1b81151a6a7d0966aca1b4a1d0f3022	
Hash	6dca0ea8a52a323b2ae173ef75d7ebb1cc6f909c855e76676a6478b9e40fb861	
Hash	c852d56ef0db5f91ee7a5f206b12c3b48dbcca6a5b85baeb0276b9816143489b	

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1078.002 Domain Accounts (initial-access)
- **Observed here:** T1078.002 Domain Accounts was the initial-access control point; blocking a means-of-entry rarely stops a determined actor, so the pivot projects forward to the execution stage they must still reach.
- **Projected pivot:** T1047 Windows Management Instrumentation (execution)
- **Basis:** of the 29+ groups that use Domain Accounts, this pairing runs 1.8x above base rate, a disproportionately-coupled move rather than the obvious one.

Having been blocked from using stolen domain accounts (T1078.002), the adversary could attempt to leverage Windows Management Instrumentation (T1047) to execute commands or scripts on remote systems by invoking wmicprvse.exe locally, thereby bypassing credential requirements and moving laterally through WMI queries or event subscriptions. The defender should monitor wmicprvse.exe child-process creation; restrict remote WMI (DCOM) at the host firewall; enable WMI-Activity operational logging.

Also plausible (same tactic): T1569 System Services (n=13, lift 2.0), T1053 Scheduled Task/Job (n=31, lift 1.4)

Detection and hardening for the pivot (T1047 Windows Management Instrumentation)

- **Telemetry:** Sysmon (WMI events); Microsoft-Windows-WMI-Activity/Operational
- **Detect:**
 - Sysmon 19/20/21 (WMI event filter/consumer/binding) for persistence
 - wmic.exe / WmiPrvSE.exe spawning shells; remote WMI process creation
 - WMI-Activity/Operational operations from unusual users/hosts
- **Harden:**
 - Restrict WMI remote access; monitor permanent WMI subscriptions
 - Least-privilege; segment management protocols
- **MITRE:** M1040 Behavior Prevention, M1038 Execution Prevention, M1026 Privileged Account Management · DS0009 Process, DS0005 WMI, DS0017 Command